

Code templates & reference notes

Track 16.6 – AI on AWS with Amazon Bedrock · 16-ai-tech-stack/tracks/aws-bedrock/code/iam_and_guardrails_examples.md

IAM, Guardrails and Network Isolation — copy-paste reference

Everything here is derived from the Amazon Bedrock User Guide. Replace every 123456789012, every ARN, and every ID. Validate each policy with IAM Access Analyzer before it goes near a production role.

Sources: - [Identity-based policy examples](#) - [Geographic cross-Region inference — IAM requirements](#) - [Model access](#) - [Guardrails — create](#) - [Guardrails with Converse](#) - [Interface VPC endpoints \(PrivateLink\)](#) - [Model invocation logging](#)

1. Least-privilege invocation policy

The mistake almost everyone makes first is "Action": "bedrock:*" on "Resource": "*", attached to the application role. That grants your web tier the ability to create Provisioned Throughput commitments, delete guardrails, and read every knowledge base in the account. An application role needs exactly two actions.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "InvokeApprovedModelsOnly",
      "Effect": "Allow",
      "Action": [
        "bedrock:InvokeModel",
        "bedrock:InvokeModelWithResponseStream"
      ],
      "Resource": [
        "arn:aws:bedrock:us-east-1:123456789012:inference-profile/us.anthropic.claude-sonnet-4-5-20250929-v1:0",
        "arn:aws:bedrock:us-east-1::foundation-model/anthropic.claude-sonnet-4-5-20250929-v1:0",
        "arn:aws:bedrock:us-east-2::foundation-model/anthropic.claude-sonnet-4-5-20250929-v1:0",
        "arn:aws:bedrock:us-west-2::foundation-model/anthropic.claude-sonnet-4-5-20250929-v1:0"
      ]
    }
  ]
}
```

Four things that trip people up here:

1. **Converse** needs `bedrock:InvokeModel`; **ConverseStream** needs `bedrock:InvokeModelWithResponseStream`. There is no `bedrock:Converse` action to grant. Omit the second and your streaming endpoint 403s in production while your unit tests pass.
2. **Foundation-model ARNs have an empty account field** — `bedrock:us-east-1::` — because the model is owned by the service, not by you. Inference-profile ARNs *do* carry your account ID.

3. **Cross-Region inference needs the model in every destination Region.** A `us.` profile can route to several Regions; authorization is evaluated against the profile, the model in the source Region, *and* the model in each candidate destination Region. List them all or you get intermittent 403s that look like a service bug.
4. **Service Control Policies that allowlist Regions will break CRIS.** Either allow the destination Regions or add an exception keyed on `bedrock:InferenceProfileArn`.

Tighter version with the condition key

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "GrantGeoCrisInferenceProfileAccess",
      "Effect": "Allow",
      "Action": "bedrock:InvokeModel",
      "Resource": [
        "arn:aws:bedrock:us-east-1:123456789012:inference-profile/us.anthropic.claude-sonnet-4-5-20250929-v1:0"
      ]
    },
    {
      "Sid": "GrantGeoCrisModelAccess",
      "Effect": "Allow",
      "Action": "bedrock:InvokeModel",
      "Resource": [
        "arn:aws:bedrock:us-east-1::foundation-model/anthropic.claude-sonnet-4-5-20250929-v1:0",
        "arn:aws:bedrock:us-east-2::foundation-model/anthropic.claude-sonnet-4-5-20250929-v1:0",
        "arn:aws:bedrock:us-west-2::foundation-model/anthropic.claude-sonnet-4-5-20250929-v1:0"
      ],
      "Condition": {
        "StringEquals": {
          "bedrock:InferenceProfileArn": "arn:aws:bedrock:us-east-1:123456789012:inference-profile/us.anthropic.claude-sonnet-4-5-20250929-v1:0"
        }
      }
    }
  ]
}
```

The condition means "these model permissions exist only when reached through *this* inference profile" — direct model calls are still denied.

2. Forcing a guardrail on every call

Granting `InvokeModel` is not enough for a regulated workload: nothing stops a developer from dropping `guardrailConfig` and calling the model bare. Use the `bedrock:GuardrailIdentifier` condition key to make the guardrail non-optional.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "InvokeOnlyWithTheApprovedGuardrail",
      "Effect": "Allow",
      "Action": [
        "bedrock:InvokeModel",
        "bedrock:InvokeModelWithResponseStream"
      ],
      "Resource": "arn:aws:bedrock:us-east-1::foundation-model/anthropic.claude-sonnet-4-5-20250929-
v1:0",
      "Condition": {
        "StringEquals": {
          "bedrock:GuardrailIdentifier": "arn:aws:bedrock:us-east-1:123456789012:guardrail/gr-abc123:2"
        }
      }
    }
  ]
}
```

Pin the **version** (:2), not **DRAFT**. **DRAFT** is mutable; anyone with console access can loosen your controls without a deploy. Verify the condition key against the [Service Authorization Reference](#) for your Region before relying on it.

3. Organization-level deny (SCP)

Model access is enabled by default in commercial Regions with the right AWS Marketplace permissions, and Bedrock auto-initiates the Marketplace subscription on first invocation. Denying `aws-marketplace:Subscribe` alone therefore does **not** block usage. To actually gate a model, deny the invocation.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyUnvettedModels",
      "Effect": "Deny",
      "Action": [
        "bedrock:InvokeModel",
        "bedrock:InvokeModelWithResponseStream",
        "bedrock:CreateModelInvocationJob"
      ],
      "NotResource": [
        "arn:aws:bedrock:::foundation-model/anthropic.claude-sonnet-4-5-20250929-v1:0",
        "arn:aws:bedrock:::foundation-model/anthropic.claude-haiku-4-5-20251001-v1:0",
        "arn:aws:bedrock:::foundation-model/amazon.titan-embed-text-v2:0",
        "arn:aws:bedrock:::inference-profile/*"
      ]
    },
    {
      "Sid": "DenyUnapprovedRegions",
      "Effect": "Deny",
      "Action": "bedrock:*",
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": ["us-east-1", "us-east-2", "us-west-2"]
        },
        "Null": { "bedrock:InferenceProfileArn": "true" }
      }
    }
  ]
}
```

The second statement is the Region allowlist with the CRIS carve-out: requests that carry an inference-profile ARN are exempt, so cross-Region routing keeps working. Test this in a sandbox OU. A Region-deny SCP without the carve-out is one of the most common ways to break Bedrock in an enterprise account.

This is also your **Module 12 / Module 14 control point**: an SCP is auditable evidence that only reviewed models are reachable, which is what an ISO 42001 or EU AI Act model-inventory control actually wants to see.

4. Logging the invocations

CloudTrail records the *management* API calls — who created a guardrail, who bought Provisioned Throughput. It does **not** record prompts and completions. For that you enable model invocation logging, which is **off by default**.

```
aws bedrock put-model-invocation-logging-configuration \
--region us-east-1 \
--logging-config '{
  "cloudWatchConfig": {
    "logGroupName": "/aws/bedrock/modelinvocations",
    "roleArn": "arn:aws:iam::123456789012:role/BedrockInvocationLogging",
    "largeDataDeliveryS3Config": {
      "bucketName": "acme-bedrock-logs",
      "keyPrefix": "large-payloads/"
    }
  },
  "textDataDeliveryEnabled": true,
  "imageDataDeliveryEnabled": false,
  "embeddingDataDeliveryEnabled": false
}'
```

Notes:

- Bodies up to 100 KB are inline; anything larger (and all binary) goes to the S3 `largeDataDeliveryS3Config` location. Configure it or you lose long documents from the record.
- Supported for `bedrock-runtime` calls only. The `bedrock-mantle` endpoint is **not** currently captured.
- `identity.arn` is populated automatically — that is how you attribute spend to a principal without any application changes:

```
fields identity.arn as principal,
       input.inputTokenCount as inTokens,
       output.outputTokenCount as outTokens
| stats sum(inTokens) as totalInput,
       sum(outTokens) as totalOutput,
       count() as calls
   by principal
| sort totalInput desc
```

- **Blocked content appears in these logs as plain text.** If a guardrail blocks a prompt full of PII, the PII is now in your log group. Apply a retention policy, encrypt with a CMK, and restrict `logs:GetLogEvents`. This is a real finding in a Module 14 audit, not a hypothetical.
- Add `requestMetadata` to every call (`{"team": "...", "environment": "..."}`) and you can slice the same logs by team without touching `identity.arn`.

5. A guardrail configuration worth copying

```
{
  "name": "acme-support-assistant",
  "description": "Support chat guardrail. Version-pinned; see ADR-0042.",
  "blockedInputMessaging": "I can't help with that. Let me get you a human.",
  "blockedOutputsMessaging": "I'm not able to answer that one.",

  "contentPolicyConfig": {
    "filtersConfig": [
      { "type": "HATE", "inputStrength": "HIGH", "outputStrength": "HIGH" },
      { "type": "INSULTS", "inputStrength": "HIGH", "outputStrength": "HIGH" },
      { "type": "SEXUAL", "inputStrength": "HIGH", "outputStrength": "HIGH" },
      { "type": "VIOLENCE", "inputStrength": "HIGH", "outputStrength": "HIGH" },
      { "type": "MISCONDUCT", "inputStrength": "MEDIUM", "outputStrength": "MEDIUM" },
      { "type": "PROMPT_ATTACK", "inputStrength": "HIGH", "outputStrength": "NONE" }
    ]
  },

  "topicPolicyConfig": {
    "topicsConfig": [
      {
        "name": "InvestmentAdvice",
        "type": "DENY",
        "definition": "Any recommendation to buy, sell or hold a specific financial instrument, or any prediction of market movement.",
        "examples": [
          "Should I put my refund into index funds?",
          "Is now a good time to buy ACME stock?"
        ]
      }
    ]
  },

  "wordPolicyConfig": {
    "managedWordListsConfig": [{ "type": "PROFANITY" }],
    "wordsConfig": [{ "text": "CompetitorCorp" }]
  },

  "sensitiveInformationPolicyConfig": {
    "piiEntitiesConfig": [
      { "type": "EMAIL", "action": "ANONYMIZE" },
      { "type": "PHONE", "action": "ANONYMIZE" },
      { "type": "NAME", "action": "ANONYMIZE" },
      { "type": "CREDIT_DEBIT_CARD_NUMBER", "action": "BLOCK" },
      { "type": "US_SOCIAL_SECURITY_NUMBER", "action": "BLOCK" }
    ],
    "regexesConfig": [
      {
        "name": "AcmeAccountNumber",
        "description": "Internal 10-digit account identifier",
        "pattern": "ACC-[0-9]{10}",
        "action": "ANONYMIZE"
      }
    ]
  },

  "contextualGroundingPolicyConfig": {
    "filtersConfig": [
      { "type": "GROUNDING", "threshold": 0.75 },
      { "type": "RELEVANCE", "threshold": 0.60 }
    ]
  }
}
```

```
}  
}
```

Design notes, because the defaults are not a policy:

- **PROMPT_ATTACK** is set to `inputStrength: HIGH, outputStrength: NONE`. Prompt-attack detection is meaningful on input. Applying it to output mostly produces false positives on legitimate text that discusses prompts.
- **BLOCK vs ANONYMIZE**. Block card numbers and SSNs — there is no legitimate reason for them to flow. Anonymize names, emails and phone numbers, because the conversation still needs to work after redaction.
- **Custom regex catches what the ML model cannot**. Your internal account format is not in anyone's PII taxonomy.
- **Contextual grounding thresholds are the RAG hallucination check**. Grounding asks "is this supported by the retrieved passages?"; relevance asks "does it answer the question?". Both score 0 to 0.99 (1 is invalid — it blocks everything). Start at 0.7 / 0.6, measure the false-block rate on a real eval set (Module 15), then tune. Do not ship a number you have not measured.
- **Guardrails do not see tool results**. With `toolConfig`, a guardrail attached via `guardrailConfig` evaluates prompts, system prompts and model responses — **not** `toolResult` content, tool descriptions, or `toolUse` arguments. If a tool returns attacker-controlled text, run `ApplyGuardrail` on it yourself before you append it to the transcript. This is the seam Module 13 spends a whole chapter on.

Using it

```
resp = client.converse(  
    modelId=MODEL_ID,  
    messages=messages,  
    guardrailConfig={  
        "guardrailIdentifier": "gr-abc123",  
        "guardrailVersion": "2",  
        "trace": "enabled",  
    },  
)  
if resp["stopReason"] == "guardrail_intervened":  
    log_assessment(resp["trace"]["guardrail"])
```

And standalone, with no model call at all — for screening retrieved documents, tool output, or user input before it ever reaches a prompt:

```
gr = boto3.client("bedrock-runtime")  
result = gr.apply_guardrail(  
    guardrailIdentifier="gr-abc123",  
    guardrailVersion="2",  
    source="INPUT",                # or "OUTPUT"  
    content=[{"text": {"text": untrusted_text}}],  
)  
# result["action"] is "GUARDRAIL_INTERVENED" or "NONE"
```

6. VPC endpoints (PrivateLink)

By default, a call to `bedrock-runtime.us-east-1.amazonaws.com` from a private subnet goes out through a NAT Gateway to the public AWS endpoint. It is TLS the whole way, but it is internet-routed, and most enterprise network reviews will stop there. Interface endpoints fix that.

Service names:

```
com.amazonaws.<region>.bedrock           # control plane
com.amazonaws.<region>.bedrock-runtime    # Converse / InvokeModel
com.amazonaws.<region>.bedrock-mantle     # Messages / Responses APIs
com.amazonaws.<region>.bedrock-agent      # agent build-time
com.amazonaws.<region>.bedrock-agent-runtime # Retrieve, RetrieveAndGenerate
com.amazonaws.<region>.bedrock-fips
com.amazonaws.<region>.bedrock-runtime-fips
```

FIPS endpoint services are available in `us-east-1`, `us-east-2`, `us-west-2`, `ca-central-1`, `us-gov-east-1`, `us-gov-west-1`.

A RAG application needs at least two: `bedrock-runtime` for generation and `bedrock-agent-runtime` for `Retrieve / RetrieveAndGenerate`. Deploying only the first is a classic half-done isolation project — retrieval quietly keeps egressing through the NAT Gateway.

Enable **private DNS** and your code needs no changes at all. Without it you must pass `endpoint_url` explicitly:

```
client = boto3.client(
    "bedrock-runtime",
    region_name="us-east-1",
    endpoint_url="https://vpce-0123456789abcdef.bedrock-runtime.us-east-1.vpce.amazonaws.com",
)
```

Attach an endpoint policy so the endpoint itself is a control, not just a route:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "InferenceOnlyThroughThisEndpoint",
      "Principal": "*",
      "Effect": "Allow",
      "Action": [
        "bedrock:InvokeModel",
        "bedrock:InvokeModelWithResponseStream"
      ],
      "Resource": "*"
    }
  ]
}
```

The 350-second trap

NAT Gateways, interface VPC endpoints and Network Load Balancers all drop idle TCP connections after 350 seconds, silently. A pooled boto3 connection that sits idle between bursts will appear to work and then hang for 70-odd seconds on the next call while the OS works through TCP retries. Fixing it takes **two** settings — either alone does nothing:

```
from botocore.config import Config
client = boto3.client("bedrock-runtime", config=Config(tcp_keepalive=True))
```

```
sysctl -w net.ipv4.tcp_keepalive_time=45 # Linux default is 7200 seconds
```

On EKS/ECS set the sysctl in the pod or task `securityContext`, an init container, or a custom node AMI.

7. Encryption and residency, briefly

- **In transit:** TLS 1.2 required, 1.3 recommended. Cross-Region inference traffic stays on the AWS network and is encrypted between Regions.
- **At rest:** Bedrock does not store prompts or completions to serve your request. What you *can* encrypt with a customer-managed KMS key are the resources you create — guardrails, knowledge bases, agents, custom models, evaluation jobs, and your own log destinations.
- **Model providers cannot see your traffic.** Bedrock deploys each provider's model into a service-team-owned Model Deployment Account; providers have no access to those accounts, to logs, or to prompts and completions.
- **Geographic vs Global CRIS is a compliance decision, not a performance one.** Geographic profiles keep processing inside a geography (US / EU / APAC). Global profiles route worldwide for roughly 10% less. If you have a residency obligation, that discount is not available to you — write down which profile you chose and why, because it will be an audit question.

8. Where this connects

Concern here	Module
Prompt injection through tool results and retrieved documents	../../../../13-ai-security/
Guardrail policy as governance evidence; model inventory via SCP	../../../../12-ai-governance/
Audit trail, residency, retention, FIPS endpoints	../../../../14-ai-compliance/
Measuring the false-block rate before you pick thresholds	../../../../15-ai-evals/